

TÀI LIỆU THIẾT KẾ CHÍNH THỨC

EGAL-SEC — SECURITY DOCTRINE

Phiên bản: 1.1.0 — APPROVED & FROZEN

Ngày ban hành: 21/07/2026

Phạm vi: Toàn bộ nền tảng Gia Phả Số 2026 / myclan.com.vn

Identity • Access • Tenant • Delegation • Ledgers • Onboarding • Edge

Trạng thái	APPROVED & FROZEN v1.1.0 — Kim chỉ nam Security toàn project
Kế thừa	v1.0.0 + phần biện 6 điểm nhấn + điều khoản hỗ trợ A–E
Hệ thống	Gia Phả Số 2026 • myclan.com.vn • EGAL Knowledge OS
Liên quan	EGAL-25.x OPD v1.1.0 • CORE Standards • auth / onboarding / ledgers

CHANGELOG v1.1.0: Bổ sung (A) Gate cache & sensitivity tier; (B) Identity Approval ≠ Tenant Activation + ma trận login; (C) Critical Notification + Outbox; (D) Delegated Access / Proxy Actor; (E) Error contract tương thích ngược. Sửa S7, Mục V–VII, X, XIV. Không hạ invariant S1–S8.

I. Mục tiêu & Phạm vi

1. Mục tiêu

- Bảo vệ identity, phiên đăng nhập và quyền truy cập multi-tenant.
- Cô lập dữ liệu theo tenant — ngăn cross-tenant read/write.
- Tách an ninh (security status) khỏi nghiệp vụ gia phả / workflow.
- Mọi quyết định nhạy cảm có audit + correlation_id.
- Shared Security/Policy — không chôn logic chỉ trong auth.service.
- Hỗ trợ đa thế hệ (kể cả ủy quyền con cháu thay trưởng họ) mà không hạ chuẩn an ninh và không share credential.
- Cân bằng Defense-in-Depth với hiệu năng read path (cây gia phả thao tác dày).

2. Phạm vi

- Auth, Identity admin, Onboarding, Genealogy, Tenant, Finance, Worship, Events, Notifications, Ledgers, Edge.

3. Ngoài phạm vi

- Chi tiết mã hóa at-rest nhà cung cấp; physical/OS hardening; legal full per jurisdiction.

II. Nguyên tắc cốt lõi (Invariants) — không đàm phán

S1 — Defense-in-Depth

Không phụ thuộc một lớp. Áp dụng theo sensitivity tier (xem VII): Read path được rút gọn có kiểm soát; Sensitive write vẫn full depth + DB re-validate.

S2 — Least Privilege

Mặc định từ chối. Nâng quyền chỉ qua workflow có audit. Ủy quyền (delegation) phải scope hẹp + thời hạn + revoke được — không thay bằng share account hoặc over-grant CLAN_ADMIN.

S3 — Tách lớp trạng thái

users.status	= an ninh & vòng đời tài khoản
tenants.status	= vòng đời không gian dòng họ
members.status	= tồn tại trên cây gia phả
branches.status	= trạng thái nhánh
onboarding_cases.status	= workflow onboarding
JWT claims	= snapshot – re-validate khi nhảy cảm

S4 — Tenant Isolation

Mọi truy vấn/ghi nghiệp vụ buộc tenant_id (SYSTEM_ADMIN bypass có audit). x-tenant-slug chỉ context — service verify resource.tenant_id.

S5 — Never Trust the Client

UI lock / client role = UX only. Enforce tại middleware + service policy.

S6 — Auditability & Correlation

correlation_id xuyên request → BPL → audit → notifications/outbox. Reject/Cancel không xóa evidence. Delegation: ghi cả actor_id và on_behalf_of.

S7 — Fail Safe, Fail Observable (phân tầng)

Non-critical side-effect có thể Silent Emit sau commit. Critical Security Notification bắt buộc Outbox đồng transaction — không try/catch nuốt mất event. Identity transaction không fail chỉ vì delivery kênh (email/zalo) down; nhưng record outbox/notification PENDING phải tồn tại.

S8 — Human Authority

Duyệt/khóa/nâng quyền có actor người. Khi ủy quyền: grantor giữ authority; grantee là người thao tác; ledger phản ánh đủ hai phía.

III. Mô hình phân lớp Security

Lớp	Thành phần	Trách nhiệm
L0 Edge	WAF, Turnstile, TLS, Helmet, CORS	Bot, origin, headers
L1 AuthN	JWT / session / password / OTP	Xác thực danh tính; không cấp token nếu account/tenant không đủ điều kiện login
L2 Account Gate	users.status + lock (+ cache)	CHO_DUYET, BI_KHOA, BI_CAM, TAM_NGUNG; temporary/permanent lock
L3 Tenant Gate	tenants.status + membership (+ cache)	Tenant lifecycle; same-tenant; activation pending codes
L4 AuthZ	RBAC + ownership + delegation	Roles, resource owner, proxy/on_behalf_of scopes
L5 Business Guard	Domain state machines	OPD transitions, finance rules...
L6 Data	Filters, soft-delete, PII	CHINH_THUC public; DU_BI không public
L7 Ledger	auth_logs, BPL, audit, outbox, notif	Trace, forensics, critical outbox

L2–L4 = Shared Security Services. L5 thuộc domain (OPD...). L2/L3 cache-capable — xem điều khoản A.

IV. Identity, Account & Lock

1. users.status

Status	Ý nghĩa	Hành vi mặc định
CHO_DUYET	Chờ duyệt identity	Không JWT; 423 ACCOUNT_CHO_DUYET
DA_DUYET	Identity OK	Login tùy tenants.status (ma trận V)
BI_KHOA	Khóa tạm / hỏng state → permanent	Lock engine; 403/423
BI_CAM	Cấm vĩnh viễn	403 permanent
TAM_NGUNG	Tạm ngưng kỷ luật/quản trị user	403 ACCOUNT_DISABLED
TU_CHOI	Từ chối đăng ký	Không login; policy nộp lại

2. Lock Engine

- BI_CAM → permanent.
- BI_KHOA + locked_until future + pre_lock_status hợp lệ → temporary (minutesLeft).
- BI_KHOA thiếu field → permanent (fail closed).
- Unlock: admin có quyền hoặc job hết hạn; luôn audit.

3. JWT

- Claims: userId, tenantId, role, status (snapshot); optional jti cho blacklist.
- Không cấp token nếu user không loginable theo ma trận V.
- Sensitive write: re-load user (+ tenant) từ DB — không tin claim cũ.
- Read path: JWT + blacklist/cache đủ trừ khi policy yêu cầu khác.

4. Password & Reset

- bcrypt ngoài TX dài; reset session + OTP hash; cooldown; max window; auth_logs.

V. Tenant Isolation & Lifecycle (điều khoản B — Freeze)

1. tenants.status (nghĩa chuẩn)

CHO_DUYET – mới tạo, chờ duyệt/kích hoạt
 CHO_KICH_HOAT – (khuyến nghị) identity admin OK, chờ wizard activation
 // Nếu chưa có enum: dùng TAM_NGUNG chỉ khi ĐÃ GHI RÕ
 // là holding activation – không trộn nghĩa 'phạt'
 HOAT_DONG – vận hành đầy đủ
 TAM_NGUNG – tạm dừng vận hành (kỷ luật/ops) – khác holding activation
 BI_KHOA / NGUNG_HAN / TU_CHOI – khóa / kết thúc / từ chối

Khuyến nghị schema: thêm CHO_KICH_HOAT (hoặc PENDING_ACTIVATION) để hết nhầm với TAM_NGUNG kỷ luật. Trước khi có enum: document transition table trong code processUserApproval.

2. Hai workflow độc lập (bắt buộc)

- Identity Approval: users CHO_DUYET → DA_DUYET | TU_CHOI (processUserApproval).
- Tenant Activation: tenants CHO_DUYET/CHO_KICH_HOAT → HOAT_DONG (OPD Clan Activation / admin trung tâm) — có config tree, rules, invite.

Không gộp atomic “duyet user = HOAT_DONG clan” trừ quyết định product riêng có BPL.

3. Ma trận Login (users × tenants)

users	tenants	Login?	Code / UX
CHO_DUYET	*	Không	423 ACCOUNT_CHO_DUYET
BI_KHOA/BI_CAM/TAM_NGUNG/TU_CHOI	*	Không	403/423 theo lock engine
DA_DUYET	CHO_DUYET	Hạn chế	423 TENANT_PENDING_ACTIVATION — không full app
DA_DUYET	CHO_KICH_HOAT hoặc holding	Hạn chế	423 TENANT_ACTIVATION_REQUIRED — wizard kích hoạt clan
DA_DUYET	HOAT_DONG	Có	Full (trừ onboarding member L5 gates)
DA_DUYET	TAM_NGUNG (ops)	Không/hạn chế	403 TENANT_DISABLED
DA_DUYET	BI_KHOA	Không	403 TENANT_DISABLED
SYSTEM_ADMIN	*	Có	Bypass có audit

4. Notification & UX — cấm lệch pha

- USER_APPROVED = chỉ identity OK — nội dung không hứa “vào đầy đủ hệ thống” nếu tenant chưa HOAT_DONG.
- Sau duyệt CLAN_ADMIN tạo clan: gửi thêm CLAN_ACTIVATION_REQUIRED / TENANT_PENDING khi cần bước activation.
- Align code processUserApproval với ma trận này (ticket bắt buộc kèm Freeze).

5. Cô lập dữ liệu

- Admin tenant chỉ trong tenant; merge targetParent cùng tenant + CHINH_THUC.
- Forbidden cross-tenant IDOR trên case/member/fund/...

VI. Roles, Ownership & Delegated Access (điều khoản D — Freeze)

1. users.role ladder

- SYSTEM_ADMIN → CLAN_ADMIN → TRUONG_*/EDITOR → USER → VIEWER → GUEST/KHAC.
- users.role = quyền ứng dụng; members.role = vai trò gia tộc — không thay AuthZ API.

2. Ownership

- Chủ onboarding case: user_id == actor.id (hoặc grantee có delegation scope phù hợp).
- Admin: ADMIN_ROLES + same tenant (hoặc SYSTEM_ADMIN).
- Không self-elevate lên CLAN_ADMIN qua Member Onboarding merge.

3. Delegated Access / Proxy Actor (bắt buộc có chỗ trong kiến trúc)

Bài toán: Trưởng họ / người có Human Authority không nhất thiết là người gõ máy; con cháu/thư ký thao tác giúp — không share password, không over-grant CLAN_ADMIN.

```
delegation {
  id, tenant_id,
  grantor_user_id, // người ủy quyền (authority)
  grantee_user_id, // người được thao tác
  scopes[],       // ONBOARDING_REVIEW | TREE_EDIT | MEMBER_UPDATE | ...
  valid_from, valid_to, status // ACTIVE | REVOKED | EXPIRED
}
```

- Grantee login bằng account riêng (DA_DUYET).
- authorize: role đủ OR hasActiveDelegation(grantor, scope, tenant).
- Ledger: actor_id = grantee; on_behalf_of = grantor — bắt buộc trên BPL/audit (S6+S8).
- Revoke tức thì; hết hạn tự EXPIRED; không delegation ngầm vô thời hạn.
- Implementation có thể SEC-2/3; Doctrine Freeze đã chốt mô hình — cấm force-fit share account.

VII. Request Pipeline theo Sensitivity (điều khoản A + rút gọn điểm 5)

1. Ba track

Track	Áp dụng	Chuỗi
Light Read	GET tree, list, detail, đọc notif	Edge → AuthN → TenantGate(cache) → Account soft/cache → Controller
Standard Write	POST/PATCH nghiệp vụ thường	+ AccountGate + Authorize (+ Delegation) + RateLimit + L5 policy + TX
Heavy / Security	Approve user/onboarding, merge, activate clan, lock, role, fund out	Full + DB re-validate user&tenant + TX + Outbox critical

2. Điều khoản A — Cache L2/L3

- L2/L3 phải cache-capable: Redis production khuyến nghị; dev có thể memory.
- Keys gợi ý: user:gate:{id}, tenant:gate:{id}, token:bl:{jti}.
- TTL ngắn (ví dụ 30–120s) + invalidate khi: approval, lock/unlock, tenant status, logout/revoke, role change.
- Read: JWT + cache/blacklist — không query DB users/tenants mỗi GET tree.
- Heavy write: bỏ qua cache freshness — query DB bắt buộc.
- SEC-1 có thể ship gate in-process cache; contract đủ để gắn Redis sau không đổi API policy.

3. Thứ tự middleware gợi ý

```
Edge → ratelimit(optional early) → authenticate →
[Light] tenantGate(cached) → controller
[Write] accountGate → tenantGate → authorize → controller → service L5 → TX
[Heavy] accountGate(DB) → tenantGate(DB) → authorize → policy → TX + outbox
```

VIII. Domain-specific Gates

1. Auth

- login: password + ma trận V trước sign JWT.
- register: rate limit, CHO_DUYET, isNewClan → tenant CHO_DUYET.
- processUserApproval: adminNote bắt buộc; same tenant; attempt_no; BPL+audit trong TX; critical outbox USER_APPROVED/REJECTED.

2. Onboarding (OPD v1.1.0)

- L5 state machine; IDOR case/tenant; merge preconditions; không public DU_BI.
- Heavy: approve/reject/merge/activate.

3. Genealogy read

- Default CHINH_THUC + branch policy; DU_BI chỉ chủ case/admin.

4. Notifications

- Đúng tenant/user; critical = outbox (IX).

IX. Notification Criticality & Outbox (điều khoản C — Freeze)

1. Phân loại

Hạng	Ví dụ	Yêu cầu
Critical Security	USER_APPROVED/REJECTED, PASSWORD_CHANGED, ROLE_CHANGED, ACCOUNT_LOCKED, ONBOARDING_APPROVED/REJECTED/MERGED (owner)	Insert outbox/notif PENDING trong cùng TX với thay đổi identity/security; worker gửi sau; retry + DLQ + alert
Business important	ONBOARDING_SUBMITTED → admin	Outbox hoặc same-TX PENDING; retry
Non-critical	Comment, reminder mềm, marketing nội bộ	Silent Emit sau TX; nuốt lỗi không fail business

2. S7 sửa chính thức

- Delivery kênh (SMTP/Zalo) down ≠ rollback identity — nhưng mất record critical là vi phạm Doctrine.
- Cấm pattern: commit user approved + try/catch trống quanh create notification critical.
- Register USER_REGISTERED có thể non-blocking emit nếu đã có persist path; approval/reject user = critical.

X. Shared Security Architecture & Error Contract

1. Target layout

```
config/securityConfig.js
middlewares/: authenticate, accountGate, tenantGate, authorize, rateLimit
modules/security/:
  lock.service.js | policy.service.js | token.service.js
  (optional) delegation.service.js
modules/auth/auth.service.js - identity flows only
modules/onboarding/*        - L5; gọi policy L2-L4
```

2. Unified error shape

```
{ "success": false, "error": { "code": "...", "message": "...", "details": {} } }
HTTP: 401 AuthN | 403 AuthZ/Disabled | 423 Locked/Wrong state | 429 | 409
```

3. Điều khoản E — Tương thích ngược (SEC-1)

- Giữ các code FE đã ship: ACCOUNT_CHO_DUYET, ACCOUNT_DISABLED, TENANT_CHO_DUYET, ...
- Chuẩn hóa bọc shape; thêm code mới (TENANT_ACTIVATION_REQUIRED, TENANT_PENDING_ACTIVATION, TENANT_DISABLED) song song.
- Không đổi 423↔403 hàng loạt không changelog + bảng map old→new trong handoff.
- SEC-1 = extract gates + dual-contract — không big-bang rename.

XI. Edge, Config & Ops

- Helmet/CSP; CORS ALLOWED_ORIGINS + Authorization, x-tenant-slug, x-correlation-id.
- Turnstile: register, login (policy), forgot-password, onboarding case/submit/branch.
- Rate limit: auth + OTP + onboarding create/submit.
- Secrets chỉ env/securityConfig; production không leak err.message.

XII. Dữ liệu nhạy cảm gia đình

- Minimize public surface; temp_* → members sau duyệt/onboarding.
- Soft-delete; hard-delete có BPL; genealogy default CHINH_THUC.
- Retention: auth/OTP ngắn; BPL/audit dài (tranh chấp dòng họ).

XIII. Logging & Monitoring

- auth_logs mọi attempt; BPL/audit/outbox critical.
- Alert: brute IP, spam case, MERGE_FAILED lặp, elevate lạ, cross-tenant deny spike, outbox DLQ.
- Không log password/OTP/JWT full.

XIV. Lộ trình triển khai (Q1-safe)

SEC-0 — Freeze Doctrine (done)

v1.1.0 Approved & Frozen; map deviation code; ticket align processUserApproval ↔ Mục V.

SEC-1 — Extract & Middleware + Compat

1. Extract lock/account/tenant/token policy từ auth — Q1 không đổi behavior login ngoài ma trận đã chốt.
2. Middleware thật; onboarding bỏ placeholder.
3. Error dual-contract (E); Light vs Write pipeline tối thiểu.
4. Cache contract L2/L3 (memory OK trước).

SEC-2 — Harden

1. Redis gates; Turnstile/rate onboarding; genealogy CHINH_THUC default.
2. Outbox critical (C); DB re-validate heavy paths.
3. Align tenant holding status / CHO_KICH_HOAT.

SEC-3 — Delegation & completeness

4. delegation.service + UI ủy quyền; policy scopes.
5. Expire onboarding + temp unlock jobs; security checklist mọi module mới.

XV. Quan hệ EGAL / OPD / CORE

- OPD = L5 onboarding; SEC = L0–L4 + L7 + tiering + delegation.
- Human Authority + on_behalf_of khi proxy.
- correlation_id bắt buộc security-sensitive BP.

XVI. Điều khoản Freeze v1.1.0 (checklist)

1. A — L2/L3 cache-capable; Read dùng cache/JWT; Heavy write re-DB.
2. B — Identity Approval $\neq$ Tenant Activation; ma trận login; mã `TENANT_*_ACTIVATION`; align `processUserApproval` + `notif`.
3. C — Critical Security Notification = Outbox cùng TX; Non-critical = Silent Emit.
4. D — Delegated Access: grantor/grantee/scopes/time; ledger actor + `on_behalf_of`.
5. E — SEC-1 dual error contract; không big-bang breaking FE codes.

XVII. Kết luận

EGAL-SEC v1.1.0 giữ vững việc tách Security khỏi “chỉ `auth.service`”, đồng thời operationalize: hiệu năng read path, lifecycle clan/user, outbox critical, ủy quyền đa thể hệ, pipeline theo tier, và an toàn refactor FE.

Ba quyết định cốt lõi không đổi: Shared Security L2–L4; mọi domain theo pipeline có tier; Tenant isolation + không public `DU_BI` + audit nâng quyền (+ delegation khi ủy quyền).

Bản này là kim chỉ nam triển khai SEC-1 trở đi và review an ninh mọi module myclan.com.vn.

— HẾT TÀI LIỆU —

EGAL-SEC Security Doctrine v1.1.0 • APPROVED & FROZEN
Gia Phả Số 2026 • myclan.com.vn • 21/07/2026

BẢN RÀ SOÁT THỰC THI (CHECKLIST DÀNH CHO NICK/DEV KHI SHIP CODE)

Để triển khai các điều khoản v1.1.0 vào code Node.js/Prisma một cách suôn sẻ, bác cần lưu ý 4 chi tiết kỹ thuật nhỏ này trong quá trình làm Phase SEC-1 & SEC-2:

1. Lưu ý đối với Điều khoản C (Critical Notification Outbox)

- **Thực tế DB Transaction trong Prisma:**

Khi ghi Outbox cùng Transaction với `users.update` (trong luồng `processUserApproval`), hãy đảm bảo bằng `outbox_events` (hoặc `notifications` ở trạng thái `PENDING`) nhận đủ `correlation_id` và `payload`.

- **Cạm bẫy:** Worker cào Outbox gửi Mail/Zalo cần có cơ chế **Idempotency (Chống gửi trùng)**. Khi Worker retry một Job bị lag, nó không được gửi 2-3 email "Tài khoản của bạn đã được duyệt" cho cùng một `correlation_id`.

2. Lưu ý đối với Điều khoản D (Delegation Scope in Prisma Queries)

- **Thao tác DB khi có `on_behalf_of`:**

Khi Grantee (cháu) thao tác trên cây đại diện cho Grantor (Cụ/Trưởng họ), Middleware `AuthZ` sẽ đính kèm thông tin delegation vào `req.delegationContext`.

- **Cụ thể:** Hàm ghi Log Audit bắt buộc phải truyền đủ:

JavaScript

```
await auditService.logAction(
```

```
'CAP_NHAT', 'members', memberId,
oldData, newData,
req.user.id, // actor_id (Grantee)
finalReason,
tenantId,
correlationId,
tx,
req.delegationContext?.grantor_user_id // on_behalf_of (Grantor)
);
```

3. Lưu ý về Cache Invalidation (Điều khoản A - Redis/Memory Gate)

- **Luồng Invalidate:** Khi Admin thực hiện Lock/Unlock User hoặc thay đổi trạng thái Tenant, ngoài việc UPDATE vào Database, Service phải chủ động gọi hàm `cache.del('user:gate:userId')` và `cache.del('tenant:gate:{tenantId})`.
- Tránh tình trạng User đã bị khóa dưới DB nhưng vẫn gửi Light Read API thành công trong vòng 120 giây TTL do Cache chưa bị xóa.

4. Khớp Enum `tenants.status` giữa DB và Code (Điều khoản B)

- Nếu Schema Database hiện tại chưa chạy Migration thêm enum `CHO_KICH_HOAT` (hoặc `PENDING_ACTIVATION`), bác nên chọn phương án dùng tạm `TAM_NGUNG` nhưng kèm metadata: `{ reason: 'HOLDING_ACTIVATION' }` đúng như tài liệu hướng dẫn ở Mục V.1 để tránh vỡ Schema DB production hiện tại.